

PREMIER HEALTHCARE ALLIANCE, L.P.
Data Stewardship Program

PART VI

PRIVACY EVENT RESPONSE POLICIES

Version 2022.3.16

TABLE OF CONTENTS

	<u>PAGE</u>
PE-1. DUTY TO REPORT SUSPECTED PRIVACY EVENTS AND VULNERABILITIES.....	1
A. Definitions of a Privacy Event and a Privacy Vulnerability.....	1
B. Duty to Internally Report Privacy Events and Vulnerabilities	2
C. Reporting Responsibilities of Supervisors	2
D. Receiving Reports from Customers, Vendors or Subcontractors	2
PE-2. INVESTIGATION AND REMEDIATION.....	3
A. Privacy Officer's Responsibility	3
B. Response Team	3
C. Response to Privacy Events.....	4
D. Common Remedial Measures	5
E. Response to Reports of Privacy Vulnerabilities	6
F. Taking Disciplinary Action Where Appropriate	7
G. No Public Release of Information	8
PE-3. PRIVACY BREACH NOTIFICATION	9
A. Evaluation of Notification Obligations	9
B. Breaches of Unsecured PHI	9
C. Breach Notification by Premier as Business Associate or Business Associate Subcontractor	10
D. Breach Notification by Premier as Covered Entity	11
E. Additional State Law Considerations	12
Premier will evaluate applicable state laws individually to comply with any additional requirements pertaining to Breaches	12
F. Law Enforcement Delay.....	13
PE-4. DOCUMENTATION AND POST EVENT REVIEW	14
A. Reports	14
B. Response Team Notes	14
C. Log	14
D. Post-Event Review	15
E. Retention Period.....	15

PE-1. Duty to Report Suspected Privacy Events and Vulnerabilities

A. Definitions of a Privacy Event and a Privacy Vulnerability

1. Privacy Event. A “**Privacy Event**” is any suspected unauthorized acquisition, use or access to Protected Data. Privacy Events can include, but are not limited to, the following:

- (i) Loss or theft of computers or portable devices, including laptops, Blackberries, iPhones, or any other electronic storage device, regardless of whether they are known to contain Protected Data;
- (ii) Loss or theft of documents containing Protected Data, or the loss of storage USB drives or CDs containing Protected Data;
- (iii) Misdirected email, regular mail, overnight or hand deliveries, and faxes containing Protected Data;
- (iv) Efforts to hack into Premier’s Information Systems or a computer or electronic device used by Premier Personnel;
- (v) Unauthorized use or disclosure of a password or keycard;
- (vi) Premier Personnel receiving a virus or malware alert on one’s computer;
- (vii) When an unauthorized person enters a secure area on Premier’s premises;
- (viii) Dumping Protected Data into unsecured bins, including recycling bins, rather than shred or confidential destruction bins; and
- (ix) Failing to use or process Protected Data consistently with the Program’s Policies.

2. Privacy Vulnerability. A “**Privacy Vulnerability**” includes situations where behaviors or circumstances increase the risk that a Privacy Event will occur, or that can undermine Premier’s Policies or threaten the security of Premier’s physical or Information Systems environment. Privacy Vulnerabilities include circumstances where any of Premier’s business procedures, Information Systems, or documents, databases and systems containing Protected Data may exist in a state, or appear to exist in a state, that could lead to or cause a Privacy Event. Some examples of Privacy Vulnerabilities include without limitation:

- (i) Suspected vulnerabilities or “loopholes” in Premier’s security systems;
- (ii) Leaving overnight packages in unsecured areas for FedEx pickup; and

- (iii) Leaving laptops or other portable devices in areas vulnerable to theft, such as in checked luggage, and in plain view in unattended automobile, for example

B. Duty to Internally Report Privacy Events and Vulnerabilities

1. Mandate to Report. Personnel must report immediately all known or suspected Privacy Events and Vulnerabilities. For purposes of these Policies, the term “**immediately**” means as soon as possible, but in no event longer than 24 hours from the time of learning the facts that cause one to suspect or believe that a Privacy Event or Vulnerability has occurred. In addition, all Personnel must be attentive to *potential* Privacy Events and Vulnerabilities and report those pursuant to these Policies as well.

If you have any doubt about whether an incident triggers an obligation to make an internal report pursuant to this policy, you should err on the side of caution and make the report.

2. Method of Reporting. All reports should go to one or more of the following, as appropriate:

- By using the “Report an Incident” button off of the Premier Privacy internal website;
- By *telephone* to the appropriate Privacy Officer or member of the Incident Response team;
- In *person* to a direct supervisor; or
- By any method to Premier’s legal counsel, appropriate Privacy Officer, Chief Security Officer, or member of the Incident Response or Data Strategy Working Committee.

C. Reporting Responsibilities of Supervisors. Whenever a manager or supervisor receives a report of an actual or suspected Privacy Event or Vulnerability, the manager or supervisor must immediately notify the appropriate Privacy Officer.

D. Receiving Reports from Customers, Vendors or Subcontractors. Any Personnel who receive notice of a Privacy Event or Vulnerability by a customer, vendor or subcontractor to Premier must immediately forward the information to the appropriate Privacy Officer, and the Privacy Officer will alert the Response Team, as appropriate, without unreasonable delay.

PE-2. Investigation and Remediation

A. Privacy Officer's Responsibility.

1. Generally. The appropriate Privacy Officer is authorized and responsible for taking all steps necessary to identify, contain, eradicate and recover from all Privacy Events and Vulnerabilities. The appropriate Privacy Officer is responsible for determining which Privacy Events warrant convening the Response Team. The appropriate Privacy Officer, however, may convene a Response Team if the appropriate Privacy Officer suspects that a Privacy Event may also constitute a Privacy Breach (as defined below).

2. Timeframe. After the appropriate Privacy Officer receives notice of an actual or potential Privacy Event or Vulnerability, the appropriate Privacy Officer will commence investigation without unreasonable delay. As soon as practicable, and in accordance with any applicable commitments in a Business Associate Agreement or other contractual requirement, after the appropriate Privacy Officer receives the notice, the Privacy Officer and any applicable Response Team will make a determination as to whether a Privacy Event or Vulnerability has occurred.

B. Response Team.

1. Mission of the Response Team. Premier and its Covered Entities maintain standing, multi-disciplinary “**Response Teams**” that, if convened by the appropriate Privacy Officer, are responsible for evaluating, investigating and resolving report of a Privacy Event. Where the appropriate Privacy Officer does not convene the Response Team, it is the appropriate Privacy Officer's responsibility to evaluate, investigate and resolve reports of Privacy Events.

2. Composition of the Response Team.

(i) Ex Officio Members. In all cases, the Premier Response Team includes the Privacy Officers, one member of Premier's risk management committee, one member of the corporate ethics and compliance committee, and one member of Premier's Information Management Committee. In cases of a Premier Covered Entity, the Response Team includes the Privacy Officer, a security officer, and the Covered Entity's Chief Executive Officer.

(ii) Additional Members. The appropriate Privacy Officer is responsible for determining the composition of the Response Team with respect to any non-ex officio members. As needed and appropriate, the Response Team may also include additional members, such as the Data Stewards, Premier's Chief Security Officer, Premier's Director of Communications, and Premier's legal counsel.

(iii) Additional Support. The Response Team will also enlist the assistance of local IT Department staff as needed in connection with each incident.

3. Standards of Conduct for the Response Team. During investigation and remediation of Privacy Events and Vulnerabilities, Premier and the members of the Response

Team will conduct themselves in a manner designed to comply with any Applicable Laws, ethical and professional obligations and contractual obligations, if any, that may apply.

C. Response to Privacy Events.

1. Initiation of the Investigation. Upon being convened to evaluate a report of a Privacy Event, Premier's Response Team will conduct an investigation. This evaluation will commence within 24 hours of the initial report of the Privacy Event.

2. Conduct of the Investigation. The Response Team will direct and coordinate all activities involved in the investigation. To the extent possible, the Response Team will assign specific responsibilities for follow-up and gathering of additional facts at the initial meeting. As to any Privacy Event, Premier should seek to:

- (i) Identify the problem;
- (ii) Identify the cause(s) of the Privacy Event and whether non-compliance with Premier's Policies contributed to the Event;
- (iii) Contain the problem by doing the following:
 - (a) Determine appropriate next steps;
 - (b) Flag the appropriate accounts to freeze (if any);
 - (c) Consult with IT Department to determine computer system vulnerabilities or problems;
 - (d) If the Privacy Event involves unauthorized access to a computer system, perform necessary security mitigations such as a change username and password if appropriate; and
 - (e) If Privacy Event involves theft, attempt to preserve Records or evidence that could be helpful to law enforcement.
- (iv) Eradicate the problem;
- (v) Recover from the Privacy Event;
- (vi) Document the Privacy Event and all steps taken in connection therewith;
- (vii) Determine whether changes to these Policies are warranted; and
- (viii) Conduct a follow-up analysis of the Privacy Event and the response which documents the elements of this Section, the appropriateness of the remedial measures, whether or not any

additional remedial measures are necessary, and the sufficiency of documentation regarding the Privacy Event.

D. Common Remedial Measures. If deemed appropriate by the appropriate Privacy Officer and the Response Team, Premier may elect to undertake the following steps in response to the following most common types of Privacy Events:

1. Unauthorized Access to Premier's System

- (i) If appropriate, immediately terminate further access to the affected system or network, including shutting down particular applications or third party connections, reconfiguring firewalls, changing computer access codes and modifying physical access controls;
- (ii) Identify which systems and Records were affected;
- (iii) Inspect logs for unauthorized access or modifications to system or user privileges.
- (iv) Attempt, as appropriate, to preserve the compromised machine or system in its active state by isolating it from the system network;
- (v) Determine whether compromised Records or systems contained or exposed Protected Data;
- (vi) Monitor systems and the network for signs of continued intruder access;
- (vii) Notify the appropriate persons or entities, including law enforcement or regulatory agencies, if applicable; and
- (viii) Take appropriate remedial steps to prevent any future unauthorized access.

2. Accidental Dissemination of Records to an Unauthorized Recipient

- (i) Immediately attempt to recall the compromised Records;
- (ii) Determine whether affected Records contained Protected Data
- (iii) Determine the encryption status of the compromised records
- (iv) Evaluate notification obligations, and notify the appropriate data subjects or entities, including law enforcement or regulatory agencies, if applicable; and
- (v) Take appropriate remedial steps to prevent accidental dissemination of Records in the future.

3. Reports of Lost or Stolen Devices that may contain Protected Data

- (i) Immediately attempt to locate the lost device and determine the encryption status of the lost device.
- (ii) Determine whether the device contained Protected Data;
- (iii) If a portable electronic device (such as a Blackberry), commence remote wiping procedures;
- (iv) Examine, and, if necessary, replace locks and other physical security instruments which may have been compromised as a result of the Privacy Event;
- (v) Evaluate notification obligations;
- (vi) Notify the appropriate data subjects or entities, including appropriate law enforcement agencies, if applicable; and
- (vii) Take appropriate remedial steps to prevent such incidents in the future.

4. Unauthorized Password Disclosure. Aside from initial Password assignment and Password-reset situations, if there is reason to believe that a Password has been disclosed to someone other than the authorized user:

- (i) The Password must be immediately changed;
- (ii) The system administrator will immediately inspect logs for unauthorized access or modifications to user privileges;
- (iii) As needed, take the actions listed in the Unauthorized Access section (PE-2.D.1);
- (iv) If system security has been compromised, or even if there is a convincing reason to believe that it has been compromised, the involved system administrator should:
 - (a) reset all relevant Passwords, and
 - (b) force every Password on the involved system to be changed at the time of next log-in; and
- (v) If systems software does not provide for a system-wide password change, then a broadcast message should be sent to all Personnel telling them to change their Passwords.

E. Response to Reports of Privacy Vulnerabilities.

1. Initiation of the Investigation. Upon being notified of a Privacy Vulnerability, the appropriate Privacy Officer will evaluate the matter. This evaluation will commence within 24 hours of the initial report of the Privacy Vulnerability.

2. Conduct of the Evaluation. As to any Privacy Vulnerability, Premier, under the direction of the appropriate Privacy Officer, should seek to:

- (i) Confirm the alleged Vulnerability;
- (ii) Assess any Vulnerability, including the potential for a future Privacy Event;
- (iii) To the extent practicable, eradicate the Vulnerability; and
- (iv) Document and then review within a reasonable time period to ensure the vulnerability has been resolved.

F. Taking Disciplinary Action Where Appropriate.

1. Personnel. If any Personnel violate or appears to have violated these Policies that contributed to or caused the Privacy Event or Vulnerability, the appropriate Privacy Officer will contact and work with the Human Resources Department to conduct an appropriate review of the matter, and issue appropriate disciplinary action.

2. Business Associate or Subcontractor. If the Privacy Event or Vulnerability was made by a Premier Business Associate or Subcontractor in violation or breach of the applicable Business Associate Agreement or Downstream Subcontractor Agreement between Premier and the Business Associate or Subcontractor, the appropriate Privacy Officer will alert the Business Associate or Subcontractor as soon as reasonably possible. The appropriate Privacy Officer will work with the Business Associate or Subcontractor to end the violation that caused the Privacy Event or Vulnerability, if possible. Depending on the facts of the specific situation the appropriate Privacy Officer may do any of the following:

- (i) Provide formal notice to the Business Associate or Subcontractor of the actions that led to the Privacy Event or Vulnerability;
- (ii) Determine that the Business Associate or Subcontractor has taken satisfactory remedial steps to end the Privacy Event or Vulnerability and document the steps taken; or
- (iii) Determine whether the Business Associate's or Subcontractor's steps to end the Privacy Event or Vulnerability are unsatisfactory or unsuccessful or that further Privacy Events or Vulnerabilities are impossible to prevent. In this case, the appropriate Privacy Officer will take steps to terminate the subcontract between the Business Associate or Subcontractor and Premier.
- (iv) In conjunction with Premier's legal counsel, work with the subcontractor under the terms of the subcontract between Premier and the Business Associate or

Subcontractor to be reimbursed for any damages caused to Premier by the breach of the subcontract and for any monies owed to Premier for the Business Associate's or Subcontractor's liability under any indemnity provisions.

(v) Work with the Business Associate or Subcontractor to facilitate the return of Protected Health Information to Premier or the destruction of Protected Health Information.

G. No Public Release of Information.

1. Pre-approval. The appropriate Privacy Officer, Communications Director, and Premier's legal counsel (or their respective nominees) must pre-authorize any dissemination of information related to a Privacy Event or Vulnerability outside of Premier. This includes required disclosures to patients, customers or law enforcement or disclosures to the media. Otherwise, this Policy prohibits all Personnel from disclosing outside of Premier any incident-specific information about the Privacy Event or Vulnerability..

2. Suspicious Conduct. Personnel should also keep in mind that following loss or theft of information, wrongdoers may attempt to engage in further theft by using the lost or stolen information to gain further access to Premier's Information Systems. For example, a thief could call or send an email posing as one of the patients or customers whose data was involved in the Privacy Event, and request disclosure of further information over the telephone or by email, such as passwords, account information or system names. As a result, Premier prohibits all Personnel from disseminating any such sensitive information following a Privacy Event. Instead, Personnel should respond to any such request as follows:

(i) For inquiries from purported beneficiaries, patients or customers, Personnel should direct all such requests to the Communications Director who consults with the appropriate Privacy Officer. Any response must be in compliance with these Policies and made only after the patient's or customer's identity is confirmed.

(ii) For inquiries from any other individuals, Personnel should direct all such requests for information to the appropriate Privacy Officer. The appropriate Privacy Officer will respond to the inquiry in compliance with these Policies.

(iii) All suspicious requests for information (i.e., requests made by callers claiming to be IT Department security personnel for another office or Premier location) should be forwarded immediately to the appropriate Privacy Officer or the Chief Security Officer.

(iv) Contact the appropriate Privacy Officer if there is any doubt about whether you can release a specific piece of information.

3. Press Requests. All requests for press releases must be forwarded to Premier's Privacy Officer and Communications Director.

PE-3. Privacy Breach Notification

A. Evaluation of Notification Obligations

1. Definition. A “**Privacy Breach**” is a type of Privacy Event where the Response Team determines that the facts and circumstances, including the type of data involved in the breach, create a legal obligation for Premier to make formal notification of the event to a customer or one or more other third parties. Any use or disclosure of Protected Health Information by Premier, Personnel, a Subcontractor or Vendor that is in violation of HIPAA, the applicable Business Associate Agreement or Downstream Subcontractor Agreement is automatically a Privacy Breach because of notice obligations to the Covered Entity Customer, Upstream Business Associate, or affected individual(s), as applicable.

2. On-going Evaluation. For each Privacy Event, the Response Team (if convened) will evaluate whether the Privacy Event is also a Privacy Breach.

3. Notice Obligations. The Response Team is responsible for evaluating Applicable Laws and relevant contractual obligations and complying with any notification requirements contained therein pertaining to reportable Privacy Events, consistent with any professional and ethical obligations or limitations. The notice obligations that Premier will consider include, but are not limited to:

- Notice to appropriate regulatory agencies under Applicable Laws;
- Notice to customers or persons whose Protected Data may have been compromised, which in the case of a notice to a Covered Entity concerning Protected Health Information, must be compliant with Section PE-3.D.;
- Notice to individuals (such as patient or beneficiaries) whose Unsecured Protected Health Information may have been compromised;
- Notice to individuals whose Protected Data, other than Protected Health Information, may have been compromised, as more fully described below;
- Notice to Personnel whose Protected Data may have been compromised;
- Notice to subcontractors, vendors or other affected third parties as a result of contractual obligations.

B. Breaches of Unsecured PHI.

1. Unsecured PHI. The HIPAA Privacy Standards set forth additional requirements for when the Privacy Breach involves unauthorized Uses and Disclosures of “**Unsecured PHI**” defined to mean PHI that is not rendered unusable, unreadable, or indecipherable to unauthorized persons in accordance with methods and standards set forth by HHS. A “**Breach of Unsecured PHI**” is the (a) acquisition, access, Use, or Disclosure of Protected Health Information” (b) in a manner that is not permitted by the Privacy Standards (c) that compromises the security or privacy of the Unsecured Protected Health Information

involved and (d) that is not excluded from the definition of Breach set forth in the applicable regulations.

2. Conducting the Breach Risk Assessment. In determining whether a Breach of Unsecured PHI has occurred, Premier must determine whether the unauthorized acquisition, access, Use or Disclosure compromises the security or privacy of the Unsecured Protected Health Information. To do so, Premier must conduct a risk assessment to consider whether there is a low probability that the Unsecured Protected Health Information has been comprised based on an assessment of the following factors: (i) the nature and extent of the Protected Health Information involved, including the types of identifiers and the likelihood of re-identification; (ii) the unauthorized person who used the Protected Health Information or to whom the disclosure was made; (iii) whether the Protected Health Information was actually acquired or viewed; and (iv) the extent to which the risk to the Protected Health Information has been mitigated (“**Breach Risk Assessment**”). The Response Team is responsible for conducting the Breach Risk Assessment.

C. Breach Notification by Premier as Business Associate or Business Associate Subcontractor

1. Generally. If, after conducting the Breach Risk Assessment, the Response Team determines that a Breach of Unsecured PHI has occurred with respect to PHI that Premier received in its capacity as a Business Associate or Business Associate Subcontractor, Premier will writing, as applicable: (i) where Premier is a Business Associate, the appropriate contact person at the Covered Entity, in accordance with this Section and any specific applicable terms in the corresponding Business Associate Agreement; or (ii) where Premier is a Business Associate Subcontractor, the “Upstream” Business Associate, in accordance with this Section and any specific applicable terms in the corresponding Downstream Subcontractor Agreement. In addition, where Premier is a Business Associate or Business Associate Subcontractor, some Business Associate Agreements or Downstream Subcontractor Agreements may require that Premier inform the Covered Entity or Upstream Business Associate, as applicable, of *suspected* Breaches of Unsecured PHI. Therefore, in any cases where a Breach of Unsecured PHI is involved, the Response Team will review the applicable Business Associate Agreement or Downstream Subcontractor Agreement to determine whether suspected Breaches of Unsecured PHI also trigger notice requirements to the Covered Entity or Upstream Business Associate.

2. Content of Notice. Notice to Covered Entities and Upstream Business Associates will include the following information, as available:

(i) Identification of each individual whose Unsecured PHI has been, or is reasonably believed by Premier to have been, the subject of the Breach. If individual names are not available, Premier will provide as much detail as practicable about the Unsecured PHI that is reasonably believed by Premier to be involved in the Breach or suspected Breach;

(ii) A brief description of what happened, including the date of the Breach or suspected Breach, and the date it was discovered;

(iii) A description of the *types* of Unsecured PHI that were involved in the Breach or suspected Breach (such as whether full name, social security number, date of birth, home address, account number, diagnosis, disability code or other types of information were involved) (but will not re-transmit such information to the Covered Entity or Upstream Business Associate);

(iv) Any suggested steps (e.g., for example, contacting credit monitoring services) that the Covered Entity may want to consider suggesting that individuals take to protect themselves from potential harm resulting from the Breach, or in the case of a suspected Breach, the steps that should be taken if the Covered Entity confirms that it was indeed a Breach;

(v) A brief description of what Premier is doing to investigate the Breach or suspected Breach, to mitigate harm to individuals and to protect against any further Breaches; and

(vi) The date of completion of the investigation of the Breach;
and

(vii) A description of the process proposed by Premier to the Covered Entity or Upstream Business Associate by which individuals affected by the Breach can ask Premier questions or learn additional information.

3. Timeliness of Notification. Premier will notify the Covered Entity of the Breach or suspected Breach without unreasonable delay and in any case within the shorter of: sixty (60) calendar days after the discovery of the Breach or suspected Breach; a shorter time required by the applicable Business Associate Agreement; or a shorter time required by Applicable Law. Breaches or suspected Breaches are treated as discovered on the first day on which the Breach or suspected Breach is known to Premier or by exercising reasonable diligence would have been known to Premier.

4. Cooperation. Premier will cooperate with the Covered Entity if the Covered Entity is required to notify individuals of a Breach caused by Premier or any of its subcontractors.

D. Breach Notification by Premier as Covered Entity

1. Generally. If, after conducting the Breach Risk Assessment, the Response Team determines that a Breach of Unsecured PHI has occurred with respect to PHI that Premier received in its capacity as a Covered Entity, Premier will follow the procedures set forth in this Section.

2. Notice to Individuals. The Breach Notice must be sent to affected individuals and be made without unreasonable delay and in any case within the shorter: of (i) 60 calendar days after the discovery of the Breach; or (ii) a shorter time required by applicable state law, in which case the shorter time period will apply. The appropriate Privacy Officer will assure that Premier properly follows the written notice, substitute notice and urgent notice requirements set forth in the HIPAA Breach Notification Standards as applicable.

3. Content of Notice to Individuals. The Breach Notice to individuals must contain the following information:

(i) A brief description of what happened, including the date of the Breach and the date of the discovery of the Breach, if known;

(ii) A description of the *types* of Unsecured Protected Health Information that were involved in the Breach (such as whether full name, social security number, date of birth, home address, account number, diagnosis, disability code, or other types of information were involved) (but will not re-transmit such information to the affected individuals);

(iii) Any suggested steps affected individuals should take to protect themselves from potential harm resulting from the Breach;

(iv) A brief description of what Premier is doing to investigate the Breach, to mitigate harm to individuals, and to protect against any further breaches;

(v) A description of the process by which individuals affected by the Breach can ask Premier questions or learn additional information, which must include the creation of a toll-free telephone number, an e-mail address, web site, or postal address.

4. Notice to the Media. If the Breach involves more than 500 residents of a state or jurisdiction, Premier will, following the discovery of the Breach, notify prominent media outlets serving the state or jurisdiction. This notification will be made by the appropriate Privacy Officer, without unreasonable delay and in no case later than 60 calendar days after discovery of the Breach.

5. Notice to HHS.

(i) If the Breach involves 500 or more residents of a state or jurisdiction, Premier will, following the discovery of the Breach, provide HHS with a breach notice in accordance with the procedures specified on the HHS Office for Civil Rights Web site.

(ii) If the Breach involves fewer than 500 residents, Premier will maintain a log or other documentation of such Breaches and, not later than 60 days after the end of each calendar year, Premier must provide notice of Breaches discovered by Premier during the preceding calendar year in accordance with the procedures specified on the HHS Office for Civil Rights Web site.

(iii) All notices, log and other documentation to be sent to HHS will be provided by the appropriate Privacy Officer.

E. Additional State Law Considerations.

Premier will evaluate applicable state laws individually to comply with any additional requirements pertaining to Breaches.

F. Law Enforcement Delay

1. Generally. Premier will comply with a request from a law enforcement official and delay notification to any party if the law enforcement official informs Premier that proceeding with the notification would impede a criminal investigation or cause damage to national security.

2. Written Requests. If the statement is in writing and specifies the time for which the delay is required, Premier will comply with the delay as specified by the official.

3. Oral requests. If the statement is made orally, Premier will document the statement, including the identity of the official making the statement, and temporarily delay any legally-required notification no longer than thirty (30) days, unless a written statement is submitted to Premier by a law enforcement official during that time.

PE-4. Documentation and Post Event Review

A. Reports. For each Privacy Event or Vulnerability, the appropriate Privacy Officer will prepare a written report including the following information:

- (i) the date the information relating to the potential Privacy Event or Vulnerability was received by the appropriate Privacy Officer;
- (ii) a description of the facts and circumstances surrounding the Privacy Event or Vulnerability including, if applicable and if known: the Protected Data or Personal Information; the identification of each individual whose Protected Data or Personal Information was subject to the Privacy Event or Vulnerability; the cause of the Privacy Event or Vulnerability; the date of the incident; the manner and date of discovery of the incident; and the identity of the unauthorized recipient of the information;
- (iii) a copy of any written complaint, if any, or a general description of the verbal complaint if made by any other individual;
- (iv) a copy of any other documents or materials relevant to the potential Privacy Event or Vulnerability;
- (v) confirm that the appropriate Privacy Officer is the appropriate contact person who will answer questions relating to the investigation and resolution of the Privacy Event or Vulnerability, or if not, an indication of the appropriate contact person;
- (vi) a description of corrective actions taken or to be taken by Premier to mitigate the potential harmful effects of the Privacy Event or Vulnerability on the individuals who are the subject of the Protected Health Information;
- (vii) a description of remedial action taken or to be taken by Premier to prevent the recurrence of similar incidents; and
- (viii) the date of completion of the investigation of the Privacy Event or Vulnerability.

B. Response Team Notes. A person designated by the Response Team will document the results of the Response Team's investigation, including any remedial action taken, and keep written copies of any notifications.

C. Log. A person designated by the appropriate Privacy Officer or Chief Security Officer will keep a written log of all relevant information concerning actual or suspected Privacy Events or Vulnerabilities (including, for example, information that the use or disclosure of PHI did not constitute a Privacy Event). The log should document all steps and actions taken to identify, contain, eradicate and recover from the incident. The log should be kept in a location that is accessible only by the Response Team and any others identified by the Response Team as needing access.

D. Post-Event Review. After any Privacy Event, appropriate Privacy Officer or Chief Security Officer will conduct a post-event review. The review should include the following:

- the cause(s) of the Privacy Event;
- whether non-compliance with Premier's Policies contributed to the incident;
- the appropriateness of the response;
- the sufficiency of documentation regarding the event;
- whether further responsive action is warranted in connection with the Privacy Event; and
- whether any changes in Premier's Policies or practices relating to protection of Personal Information and Protected Data are warranted.

The Response Team will create a report describing this post-event review and findings. All written documentation relating to post-event review will be filed in a confidential file with the log information documenting the investigation.

E. Retention Period. All written documentation identified in this policy, including without limitation all breach notices, reports, and logs, will be retained for a minimum of six (6) years after the completion of the Report.